

Take my money



Mithun Mohandas
Senior Reviewer
mithun@digit.in

“The mere fact that more and more companies are losing out to hackers puts our precious data at stake”

Roughly a month ago, quite a few of us ended up getting SMSes from our banks asking to update our debit/credit card PINs. Certain banks even took a more proactive role and changed the PINs without user intervention. And then there were a few banks that even disabled CNP e-commerce transactions and removed international usage off of international debit cards (oh, the irony!). It did seem a little fishy at first but since it was for our own security, we went along with it. The extra paranoid ones like yours truly, took the opportunity to update our accounts with new passwords and PINs. But a few unlucky ones ended up being victims in one manner or the other. I was one of these unlucky few, or at least I hope the number is small.

It goes without saying that had the banks broken the news, mass chaos could have erupted resulting in bank runs i.e. when customers rush en masse to withdraw funds. But should the banks have made a disclosure? Yes, they most certainly should have. The only reason that such an issue should not be disclosed is when it could impede an investigation. Otherwise, as consumers we deserve to know if our information has been acquired by an unauthorised person.

India does not have a security breach notification law or a data breach notification law. And this becomes all the more important as more services enter the digital domain. The mere fact that more and more companies are losing out to hackers puts our precious data at stake. Just this year, we've seen multiple breaches, both foreign and Indian companies alike have had their systems compromised. The most recent include Redbus.in and quite a lot of banks. And if you were to check your email IDs against popular sites like hacked-emails.com or haveibeenpwned.com then there's a high probability that your data has been compromised in the last five years if you've been online for that long.

The Indian IT Act of 2000 isn't up to the mark given the fact that those who wrote it in the first place weren't well versed with the concepts and the lack of data breach notification laws puts us in an even worse state. There are numerous third-parties who are sub-contracted to handle your data in any

given online service today. Very few ensure that all data is within their own systems from end-to-end. And quite a few of these third-parties don't even bother with proper encryption. And don't get me started on encryption, most don't even use high-grade encryption let alone 'salt' (add random data prior to encrypting) your passwords. I've gone across all the pastebins and extracted my personal data with relative ease. Given the existing data out there, I could then create a simple wordlist to bruteforce any of the other hundreds of services I've used the same ID with. And you're in the same position as I unless you use a service that generates and manages passwords for you.

Security breach notification laws serve two primary purposes. Firstly, the awareness causes users to take measures to better protect themselves from monetary loss or identity theft. And secondly, the fear of public backlash acts as a deterrent for companies to take better care of the data they're entrusted.

This month as we delved into cyber-crime, one key thing came to most of us, that of Digital India. Let's take the Aadhar programme for example, the government hasn't even bothered to incorporate all the security measures suggested by a committee which found severe irregularities with data collection and lack of security audit mechanisms to keep a check on the collected data. Right now, we won't even know if the Aadhar system gets compromised unless we end up seeing a data dump on some darknet market going for a few hundred thousand dollars. Then again, with such lax security we wouldn't be wrong to assume that a few have already crossed that bridge. The IRCTC website was hacked earlier this year and officials have confirmed that Aadhaar numbers were present in the stolen data. The government has to lead by example and get its act together or we might as well toss away money in the streets. 

Let me know your thoughts on this column at: [@mithun_mohandas](https://twitter.com/mithun_mohandas)